Threat Modeling Report

Created on 3/20/2026 4:01:56 AM

Threat Model Name:

Owner:

Reviewer:

Contributors:

Description:

Assumptions:

External Dependencies:

Threat Model Summary:

Not Started	9
Not Applicable	9
Needs Investigation	1
Mitigation Implemented	0
Total	19
Total Migrated	0

Diagram: Diagram 1

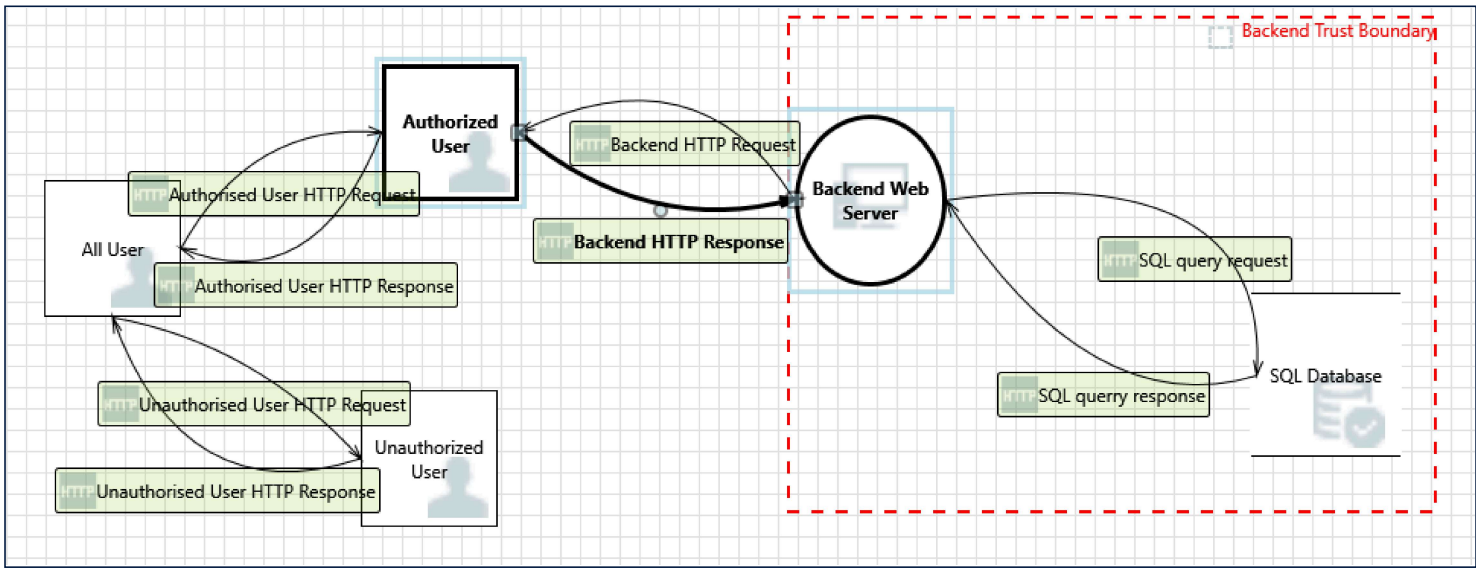
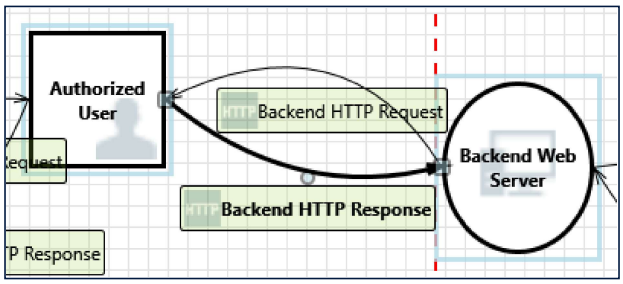


Diagram 1 Diagram Summary:

Not Started	9
Not Applicable	9
Needs Investigation	1
Mitigation Implemented	0
Total	19

Total Migrated 0

Interaction: Backend HTTP Request



1. Spoofing of the Authorized User External Destination Entity [State: Not Applicable] [Priority: High]

Category: Spoofing

Description: Authorized User may be spoofed by an attacker and this may lead to data being sent to the attacker's target instead of Authorized User. Consider using a standard authentication mechanism to identify the external entity.

Justification: <no mitigation provided>

2. External Entity Authorized User Potentially Denies Receiving Data [State: Needs Investigation] [Priority: High]

Category: Repudiation

Description: Authorized User claims that it did not receive data from a process on the other side of the trust boundary. Consider using logging or auditing to record the source, time, and summary of the received data.

Justification: <no mitigation provided>

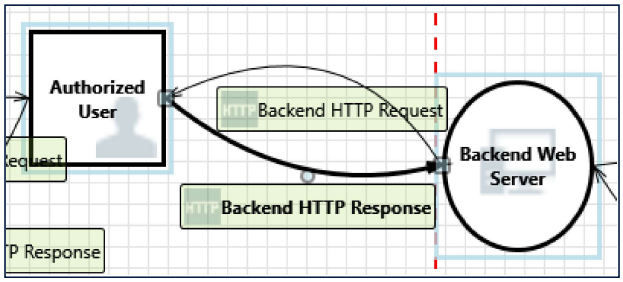
3. Data Flow Backend HTTP Request Is Potentially Interrupted [State: Not Applicable] [Priority: High]

Category: Denial Of Service

Description: An external agent interrupts data flowing across a trust boundary in either direction.

Justification: <no mitigation provided>

Interaction: Backend HTTP Response



4. Spoofing the Authorized User External Entity [State: Not Started] [Priority: High]

Category: Spoofing

Description: Authorized User may be spoofed by an attacker and this may lead to unauthorized access to Backend Web Server. Consider using a standard authentication mechanism to identify the external entity.

Justification: <no mitigation provided>

5. Potential Data Repudiation by Backend Web Server [State: Not Applicable] [Priority: High]

Category: Repudiation

Description: Backend Web Server claims that it did not receive data from a source outside the trust boundary. Consider using logging or auditing to record the source, time, and summary of the received data.

Justification: <no mitigation provided>

6. Escalation of Privilege via Improper Authorisation Controls [State: Not Started] [Priority: High]

Category: Elevation Of Privilege

Description: Attackers may gain elevated privileges by exploiting improper authorisation checks in the backend. Implement strict role based access control (RBAC) and enforce server-side authorisation checks for all sensitive operations.

Justification: <no mitigation provided>

7. Potential Lack of Input Validation for Backend Web Server [State: Not Applicable] [Priority: High]

Category: Tampering

Description: Data flowing across Backend HTTP Response may be tampered with by an attacker. This may lead to a denial of service attack against Backend Web Server or an elevation of privilege attack against Backend Web Server or an information disclosure by Backend Web Server. Failure to verify that input is as expected is a root cause of a very large number of exploitable issues. Consider all paths and the way they handle data. Verify that all input is verified for correctness using an approved list input validation approach.

Justification: <no mitigation provided>

8. Spoofing the Backend Web Server Process [State: Not Applicable] [Priority: High]

Category: Spoofing

Description: Backend Web Server may be spoofed by an attacker and this may lead to information disclosure by Authorized User. Consider using a standard authentication mechanism to identify the destination process.

Justification: <no mitigation provided>

9. Sensitive Data Exposure via Unencrypted HTTP Communication [State: Not Started] [Priority: High]

Category: Information Disclosure

Description: Data transmitted between users and the backend web server over HTTP may be intercepted by an attacker (e.g., via man-in-the-middle attacks). This could expose sensitive information such as credentials, session tokens, or application data. Enforce HTTPS using TLS encryption for all communications. Disable HTTP, implement HSTS, and ensure secure cookie flags are used. Validate certificates and prevent downgrade attacks.

Justification: <no mitigation provided>

10. Potential Process Crash or Stop for Backend Web Server [State: Not Applicable] [Priority: High]

Category: Denial Of Service

Description: Backend Web Server crashes, halts, stops or runs slowly; in all cases violating an availability metric.

Justification: <no mitigation provided>

11. Data Flow Backend HTTP Response Is Potentially Interrupted [State: Not Applicable] [Priority: High]

Category: Denial Of Service

Description: An external agent interrupts data flowing across a trust boundary in either direction.

Justification: <no mitigation provided>

12. Backend Web Server May be Subject to Elevation of Privilege Using Remote Code Execution [State: Not Started] [Priority: High]

Category: Elevation Of Privilege

Description: An attacker may exploit vulnerabilities such as improper input validation, insecure deserialization, or command injection to execute arbitrary code on the backend web server. This could allow the attacker to gain elevated privileges and fully compromise the system. Implement strict input validation and sanitization. Avoid executing user-controlled input in system commands. Use

parameterized queries and secure coding practices. Apply least privilege to processes, keep dependencies updated, and perform regular vulnerability scanning and patching.

Justification: <no mitigation provided>

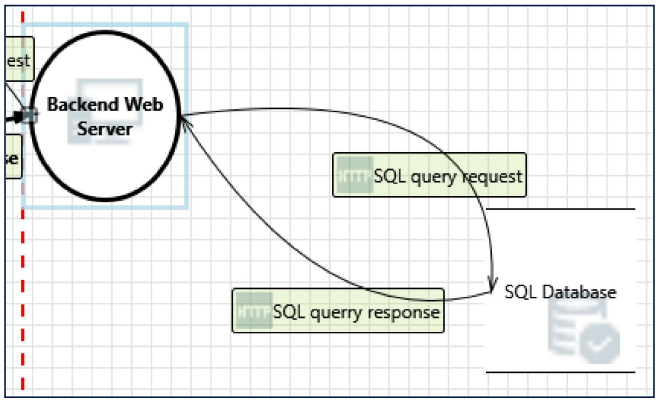
13. Elevation by Changing the Execution Flow in Backend Web Server [State: Not Applicable] [Priority: High]

Category: Elevation Of Privilege

Description: An attacker may pass data into Backend Web Server in order to change the flow of program execution within Backend Web Server to the attacker's choosing.

Justification: <no mitigation provided>

Interaction: SQL querry response



14. SQL Injection via Backend Query [State: Not Started] [Priority: High]

Category: Tampering

Description: Attacker may inject malicious SQL through user input, leading to unauthorised data access or modification. Use parameterized queries, input validation and ORM Frameworks to prevent SQL injection.

Justification: <no mitigation provided>

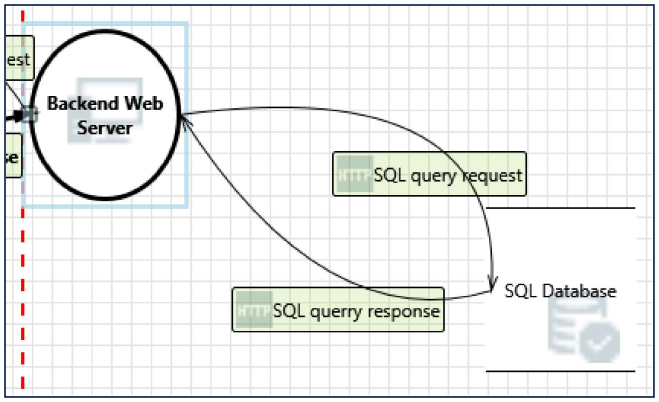
15. Weak Access Control or Backend Data Access. [State: Not Started] [Priority: High]

Category: Information Disclosure

Description: Improper data protection of SQL Database can allow an attacker to read information not intended for disclosure. Review authorization settings.

Justification: <no mitigation provided>

Interaction: SQL query request



16. Spoofing of Destination Data Store SQL Database [State: Not Applicable] [Priority: High]

Category: Spoofing

Description: SQL Database may be spoofed by an attacker and this may lead to data being written to the attacker's target instead of SQL Database. Consider using a standard authentication mechanism to identify the destination data store.

Justification: <no mitigation provided>

17. Potential SQL Injection Vulnerability for SQL Database [State: Not Started] [Priority: High]

Category: Tampering

Description: User input may be improperly validated, allowing an attacker to inject malicious SQL queries that can manipulate or access database data. Use parameterized queries, input validation, and ORM frameworks. Avoid dynamic SQL construction and enforce least privilege on database accounts.

Justification: <no mitigation provided>

18. Potential Excessive Resource Consumption for Backend Web Server or SQL Database [State: Not Started] [Priority: High]

Category: Denial Of Service

Description: An attacker may send excessive or resource-intensive requests to the backend, causing high CPU, memory, or database load and leading to service unavailability. Implement rate limiting, input size restrictions, query optimization, and resource monitoring. Use timeouts and circuit breakers to prevent overload.

Justification: <no mitigation provided>

19. Authorization Bypass [State: Not Started] [Priority: High]

Category: Elevation Of Privilege

Description: An attacker may bypass authorization checks and gain access to restricted data or functionality in the backend. Implement strong authorization controls, enforce role-based access control (RBAC), and validate user permissions for every request.

Justification: <no mitigation provided>